

Políticas de Seguridad DLP

y restricción de dispositivos USB en Windows

1. ¿Qué es el DLP?

DLP significa Data Loss Prevention, que en español se traduce como Prevención de Pérdida de Datos. Es el conjunto de medidas y herramientas que usan las empresas para evitar que la información importante se filtre, se pierda o caiga en manos equivocadas.

La fuga de información puede ocurrir de muchas maneras: alguien copia archivos a una USB para llevarlos, manda un correo con información sensible al destinatario equivocado, sube documentos a su cuenta personal de Drive, o un atacante externo logra entrar y robar datos. El DLP busca prevenir todos estos casos.

Tener una buena política de DLP es importante porque:

- Ayuda a cumplir leyes como el GDPR o HIPAA que protegen los datos personales.
- Evita pérdidas económicas por demandas, multas o robo de propiedad intelectual.
- Protege la imagen de la empresa frente a sus clientes.
- Reduce el riesgo de que un empleado se lleve información valiosa al irse.

2. Clasificación de datos

Lo primero que hay que hacer para proteger la información es saber qué tan sensible es. No todos los datos necesitan la misma protección: el logo de la empresa puede estar en cualquier lado, pero la base de datos de clientes no. Por eso se clasifican los datos en categorías.

Yo propongo tres categorías, que son las más comunes:

Categoría	Qué es	Ejemplos
Datos Públicos	Información que cualquiera puede ver.	Página web, redes sociales, folletos.
Datos Internos	Información que solo deben ver los empleados.	Manuales internos, organigramas, planes de proyecto.
Datos Sensibles	Información muy importante, su filtración causaría daño.	Datos de clientes, contraseñas, datos médicos, datos bancarios.

Los datos sensibles son los que más cuidados necesitan: deben estar cifrados, con accesos limitados y monitoreados.

3. Acceso y control (menor privilegio)

El principio del menor privilegio dice que cada persona debe tener solo los permisos que necesita para hacer su trabajo, ni más ni menos. Por ejemplo, alguien de marketing no debería tener acceso a la base de datos de nómina, aunque trabaje en la misma empresa.

Para aplicar este principio se proponen las siguientes reglas:

- Por defecto, nadie tiene acceso a nada. El acceso se va dando según se necesite.

- Cuando alguien cambia de puesto, se le quitan los accesos viejos antes de darle los nuevos.
- Cuando alguien deja la empresa, se le quitan todos los accesos el mismo día.
- Los accesos temporales (por proyecto, prácticas, etc.) tienen fecha de vencimiento.

¿Quién revisa los permisos?

Es importante que los permisos se revisen cada cierto tiempo para asegurarse de que siguen siendo necesarios. La revisión la deberían hacer los jefes de cada área junto con el equipo de TI:

Quién revisa	Qué revisa	Cada cuánto
Jefe de cada área	Permisos de su equipo	Cada 6 meses
Equipo de TI	Cuentas con permisos de administrador	Cada 3 meses
RR.HH. + TI	Cuentas de gente que se fue	Inmediato al darse de baja

4. Monitoreo y auditoría

No basta con escribir las políticas, hay que verificar que se cumplen. Para eso se usan herramientas que vigilan lo que pasa con la información.

Algunas herramientas que se pueden usar son:

- **Herramientas DLP:** como Microsoft Purview o Symantec DLP, que vigilan los archivos y bloquean cosas como mandar datos sensibles por correo personal.
- **SIEM:** herramientas como Wazuh o Splunk que recogen los registros de todo lo que pasa en los equipos y alertan cuando ocurre algo raro.
- **Registros de Windows:** el propio Visor de Eventos de Windows guarda los eventos cuando se conecta una USB, se accede a un archivo, etc.

Algunas cosas que deberían monitorearse:

- Cuando alguien conecta una USB.
- Cuando alguien copia muchos archivos seguidos.
- Cuando se accede a archivos sensibles fuera del horario laboral.
- Cuando se intenta subir archivos a sitios como WeTransfer o Mega.

5. Prevención de filtraciones

Para evitar que los datos se filtren se usan varias medidas a la vez. La idea es que si una falla, las otras sigan funcionando.

- Cifrado de los discos duros con BitLocker, así si roban una laptop no pueden leer el contenido.
- Cifrado del correo electrónico para que viaje seguro.
- Bloqueo de servicios como WeTransfer, Mega o Dropbox desde la red de la empresa.
- Restricción de los puertos USB (esto es lo que vamos a implementar en la parte 2).
- Bloqueo de la opción de imprimir documentos marcados como sensibles.

6. Educación y concientización

Aunque la tecnología ayuda mucho, al final son las personas las que usan los datos. Muchas filtraciones pasan porque alguien hizo clic en un correo de phishing o porque no sabía que no debía guardar el archivo en una USB personal. Por eso es importante capacitar al personal.

El plan de capacitación que propongo incluye:

- Una capacitación obligatoria cuando alguien entra nuevo a la empresa.
- Una capacitación anual de repaso para todos.
- Simulaciones de phishing cada cierto tiempo para ver quién cae.
- Recordatorios visuales en oficinas (carteles, pantallas).
- Un canal donde los empleados puedan reportar cosas raras sin miedo a ser regañados.

Parte 2 — Restricción de dispositivos USB en Windows

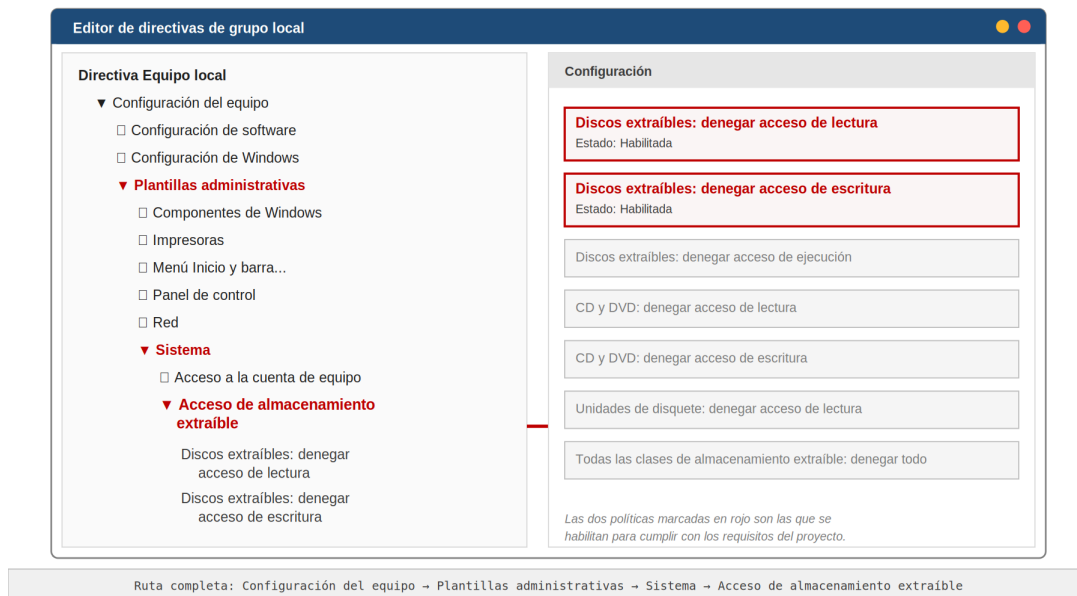
Una de las maneras más comunes de filtrar información es copiando archivos a una USB. Por eso conviene bloquear el uso de USBs en los equipos de la empresa, dejando solo a las personas autorizadas. Esto se puede hacer con el Editor de Políticas de Grupo de Windows (gpedit.msc).

¿Cómo se hace?

Los pasos serían los siguientes:

- 1. Presionar Win + R, escribir gpedit.msc y dar Enter para abrir el Editor de Políticas de Grupo.
- 2. Ir a la ruta: Configuración del equipo > Plantillas administrativas > Sistema > Acceso de almacenamiento extraíble.
- 3. Habilitar la política **Discos extraíbles: denegar acceso de lectura**.
- 4. Habilitar la política **Discos extraíbles: denegar acceso de escritura**.
- 5. Reiniciar el equipo o ejecutar gpupdate /force en una consola con permisos de administrador.

Editor de Políticas de Grupo (gpedit.msc) — Ruta a la política de USB



Captura del Editor de Políticas de Grupo mostrando dónde están las dos opciones que hay que habilitar.

¿Cómo se prueba que funciona?

Para verificar que la política funciona, hay que iniciar sesión con una cuenta de usuario normal (sin permisos de administrador) y conectar una USB. Si todo está bien configurado, debería aparecer un mensaje de "Acceso denegado" al intentar abrir la USB.

Las pruebas que se hicieron serían:

Usuario	Acción	Resultado esperado
Usuario normal	Conectar USB y leer	Acceso denegado
Usuario normal	Conectar USB y escribir	Acceso denegado
Administrador	Conectar USB y leer	Permitido
Administrador	Conectar USB y escribir	Permitido

Crear un usuario regular en Windows

Para hacer las pruebas necesitamos crear un usuario sin permisos de administrador:

- Ir a Configuración (Win + I) > Cuentas > Familia y otros usuarios.
- Clic en Agregar a otra persona a este equipo.
- Seleccionar No tengo la información de inicio de sesión > Agregar un usuario sin cuenta de Microsoft.
- Ponerle un nombre y contraseña al usuario nuevo. Por defecto se crea como usuario estándar (sin permisos de administrador).

Al iniciar sesión con este usuario nuevo y conectar una USB, ya no debería poder leer ni escribir, mientras que el administrador sí.

Excepciones para usuarios específicos

A veces hay usuarios que sí necesitan usar la USB por su trabajo (por ejemplo, técnicos de soporte). Para ellos se pueden hacer excepciones. La forma de hacerlo en Windows es usando MLGPO (Multiple Local Group Policy Objects), que permite aplicar políticas distintas a usuarios específicos en el mismo equipo.

La idea sería:

- Crear un grupo llamado, por ejemplo, USB_Autorizado.
- Meter en ese grupo a los usuarios que sí pueden usar USB.
- Crear una política específica para ese grupo que deshabilite la restricción.

Otra forma más simple es usar las cuentas de administrador para los usuarios autorizados, ya que la política aplica solo a los usuarios estándar.

Conclusiones

Con este proyecto se diseñó una política básica de DLP y se documentó cómo aplicar una de sus medidas más importantes: la restricción de USBs en Windows. Lo que aprendí es que la seguridad no es solo tecnología, también es organización (clasificar la información, controlar quién accede a qué) y formación del personal.

La restricción de USB es fácil de aplicar y muy útil, pero no es suficiente por sí sola. Hay otros canales por donde se puede ir la información (correo, internet, capturas de pantalla) que necesitan otras medidas. Por eso una política de DLP combina varias capas, no solo una.

Para mejorar este trabajo en el futuro se podría:

- Aplicar las políticas también a CDs/DVDs y discos externos por Bluetooth.
- Implementar una herramienta DLP completa que monitoree también el correo y la nube.
- Incluir capacitaciones reales al personal con métricas de cumplimiento.